

ZAP by Checkmarx

Scanning Report - EFBox

API

Generated with  ZAP on Tue 19 May 2026, at 13:02:03

ZAP Version: 2.17.0

ZAP by Checkmarx

Contents

- [About This Report](#)
 - [Report Description](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
 - [Insights](#)
- [Alerts](#)
 - [Risk=High, Confidence=Medium \(1\)](#)

- [Risk=Medium, Confidence=Medium\(1\)](#)
- [Risk=Low, Confidence=Medium\(1\)](#)
- [Appendix](#)
 - [Alert Types](#)

About This Report

Report Description

ZAP has been fed all end-points of the EFBBox-API, tested for three different users. The reports follows an Active Scan.

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <https://efbox.local:8081>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	High	Medium	Low	Total
Risk	High	0 (0.0%)	0 (0.0%)	1 (33.3%)	0 (0.0%)	1 (33.3%)
	Medium	0 (0.0%)	0 (0.0%)	1 (33.3%)	0 (0.0%)	1 (33.3%)
	Low	0 (0.0%)	0 (0.0%)	1 (33.3%)	0 (0.0%)	1 (33.3%)
	Informational	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Total	0 (0.0%)	0 (0.0%)	3 (100.0%)	0 (0.0%)	3 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High	Medium	Low	Informational
		(= High)	(>= Medium)	(>= Low)	(>= Informational)
Site	https://efbox.local 1:8081	1 (1)	1 (2)	1 (3)	0 (3)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
SQL Injection	High	2 (66.7%)
Buffer Overflow	Medium	8 (266.7%)
Application Error Disclosure	Low	1 (33.3%)
Total		3

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	7
Low	Warning		ZAP warnings logged - see the zap.log file for details	3
Low	Exceeded High	https://efbox.local:8081	Percentage of slow responses	69 %
Info	Informational	https://efbox.local:8081	Percentage of responses with status code 2xx	37 %
Info	Exceeded Low	https://efbox.local:8081	Percentage of responses with status code 4xx	40 %
Info	Exceeded Low	https://efbox.local:8081	Percentage of responses with status code 5xx	22 %
Info	Informational	https://efbox.local:8081	Percentage of endpoints with content type application/json	63 %
Info	Informational	https://efbox.local:8081	Percentage of endpoints with content type text/plain	26 %
Info	Informational	https://	Percentage of	15 %

Level	Reason	Site	Description	Statistic
	onal	efbox.local:8081	endpoints with method DELETE	
Info	Informational	https://efbox.local:8081	Percentage of endpoints with method GET	36 %
Info	Informational	https://efbox.local:8081	Percentage of endpoints with method POST	26 %
Info	Informational	https://efbox.local:8081	Percentage of endpoints with method PUT	21 %
Info	Informational	https://efbox.local:8081	Count of total endpoints	19

Alerts

Risk=High, Confidence=Medium (1)

<https://efbox.local:8081> (1)

SQL Injection (1)

▼ PUT <https://efbox.local:8081/user/login>

Alert tags

- POLICY_SEQUENCE =
- [OWASP_2021_A03](#)
- [PCI_DSS](#)
- [CWE-89](#)
- POLICY_QA_CICD =
- POLICY_DEV_CICD =

- [OWASP_2025_A05](#)
- [WSTG-v42-INPV-05](#)
- POLICY_API =
- POLICY_DEV_FULL =
- POLICY_QA_STD =
- POLICY_QA_FULL =
- POLICY_PENTEST =
- [HIPAA](#)
- [OWASP_2017_A01](#)
- [API_2023_API10](#)
- POLICY_DEV_STD =

**Alert
description**

SQL injection may be possible.

Other info

The page results were successfully manipulated using the boolean conditions [' AND '1'='1' --] and [' AND '1'='2' --]

The parameter value being modified was stripped from the HTML output for the purposes of the comparison.

Data was returned for the original parameter.

The vulnerability was detected by successfully restricting the data originally returned, by manipulating the parameter.

Request

▼ Request line and header section (254 bytes)

```
PUT https://efbox.local:8081/user/
login HTTP/1.1
Content-Type: application/json
User-Agent: PostmanRuntime/7.54.0
Accept: */*
Postman-Token: 6a75666a-
eb02-4e1d-90e8-435ba663b4c5
host: efbox.local:8081
Connection: keep-alive
content-length: 116
```

▼ Request body (116 bytes)

```
{
  "username": "DrAlban",
  "firstname": "' AND '1'='1' -- ",
  "lastname": "",
  "password": "IlikeToMoveIT1990"
}
```

Response

▼ Status line and header section (486 bytes)

```
HTTP/1.1 200
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-
Headers
X-Content-Type-Options: nosniff
X-XSS-Protection: 0
Cache-Control: no-cache, no-store,
max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Strict-Transport-Security: max-
age=31536000 ; includeSubDomains
X-Frame-Options: DENY
Content-Type: text/
plain; charset=UTF-8
Content-Length: 184
Date: Tue, 19 May 2026 10:56:40 GMT
Keep-Alive: timeout=60
Connection: keep-alive
```

▼ Response body (184 bytes)

```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJhdXRoMCIsInN1YiI6ImZjNW00Njd1LTEyNWUtdG9yYS1hODFiLWZlM2I2NWNhOTQ3MSIsImV4cCI6MTc30TE5MTgwMH0uYm41wRoi_BsHEEmYYcBoF7ZyoPLUQsA0afSejNRAyE
```

Parameter	firstname
Attack	' AND '1'='1' --
Solution	Do not trust client side input, even if there is client side validation in place. In general, type check all data on the server side. If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?' If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries. If database Stored Procedures can be used, use them. Do <i>*not*</i> concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality! Do not create dynamic SQL queries using simple string concatenation. Escape all data received from the client. Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input. Apply the principle of least privilege by using the least privileged database user possible. In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact.

Grant the minimum database access that is necessary for the application.

Risk=Medium, Confidence=Medium (1)

<https://efbox.local:8081> (1)

Buffer Overflow (1)

▼ GET <https://efbox.local:8081/folder/browse?folderID=a8c1895b-132b-49c5-8785-1e1c82147e06>

Alert tags

- [OWASP_2025_A05](#)
- [OWASP_2021_A03](#)
- [PCI_DSS](#)
- POLICY_API =
- POLICY_PENTEST =
- [OWASP_2017_A01](#)
- [API_2023_API10](#)
- [OWASP_2025_A10](#)
- [CWE-120](#)

Alert description

Buffer overflow errors are characterized by the overwriting of memory spaces of the background web process, which should have never been modified intentionally or unintentionally. Overwriting values of the IP (Instruction Pointer), BP (Base Pointer) and other registers causes exceptions, segmentation faults, and other process errors to occur. Usually these errors end execution of the application in an unexpected way.

Other info

Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error.

Request

- Request line and header section (2522 bytes)

▼ Request body (0 bytes)

Response

▼ Status line and header section (456 bytes)

```
HTTP/1.1 500
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-XSS-Protection: 0
Cache-Control: no-cache, no-store,
max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Strict-Transport-Security: max-
age=31536000 ; includeSubDomains
X-Frame-Options: DENY
Content-Type: text/
plain;charset=UTF-8
Content-Length: 21
Date: Tue, 19 May 2026 10:58:41 GMT
Connection: close
```

▼ Response body (21 bytes)

UUID string too large

Parameter

folderID

Attack

aapAvFePHf0JeQAUxkZEJZuElKBOWfYfcfUy
bdiUTtwiSmHcB0t0SoyHlXlniJkhBoKHEPmD
qEwrPhnc0ucQguLwBnlUXjZyQamLQACgqECW
jbBKS0msedsMLnIUycWNnAQREXZThRGMsrAq
FRZbUsbyeblWwYXuMviepBssDWdNyQjZwqlZ
xgijbVVHiKRrrPUFnKHvbhSIE0echQyWZxtm
yRlLQyyetocdNeiPKNTVkJGhLHawIsdCjZsb
WCwgpvYljewYgYLNKftAOPZooeleFPLGZWkS
vElviHlGMEnKuVqPYoXlAUKaHwsnJuPQskjc
ONRWoBdkFFKGFA0yjSvFxdcUQyYpqWpUuViQ

ibUsmZkihFSEFynjCnoBQijRDRoelPjaSJmc
DpSmCAASOHCgOwYKJxmbUPutcVAQxYbDQUFG
PkdVgruCLosrcNSeDXDoxXWAvXoLDlPwIyok
ctdAdtMyZhAQLnFIUMuQKBITvvyKRgOQxYhk
CWycGFYVNNYpUataZGsFZgHqAsCeYdUMHmtT
cwNSsWEpaBaBmfAigKbrfAgVWwIFcREjVSKo
UQgAtDAZRKqhIHpkEhuVvehCwYye10oYATMd
wHURxkUXyIYDsaYdcGLWTXYTtCUWJeDJHSEu
pgkJcFlnskZcvsdWZadrVEMSiLKKaNaQBpGV
LJlrEodnTmtMjMwCgmFxQqZvXymbsPfJqGok
laArjPUpYmQbqyGSMAJcpOZWocFVLwunYOHG
sKRQYhassDOINUegDkIaBIIPqIDcRcwJgnlk
lWHxWhVGOBDdWnOqPmUvxAKrNPIuhFBmTQxL
tmuQVpBxTmuNdkKLlXnCFGLWxpEsHnDLiWSF
qxFdBRdaFwHluWaLbEWbGixfoQIEYWiFY0aO
jWXnbiKHCXeMbvVTtbFkDuMWwLAUXHbTkROs
WPULstecoTSCJNMBtJeeoyORsuuHJeeEpLdq
vJaExOVZyjQyWXKMEYmSsOhggcQktaLHgWJC
SLkOLXUBRGRETvUUnmOWUhuWUbHwJfZtxrGs
JIteXxXerlKdICjCnrKPGHVZLQUAqhXIVMSG
mdRKEZuGUXGSpKTCHeAYbmmXSLEVNTThwHQkS
OQklfpQE0AIFaZWHZbBW0rPcTIkHHrTePVZZ
ALkplXYoujFlbErPWpCTuimGSMRhdIyHMfRi
KKXUOVQcfENKnokMkJcFJMtZGuSBLaXQJNAY
AwtbZVclFDesgZVbRevPvwGfrKjVbJCrGaMp
wXFMsiFMAOGxYSbayaEVGiQilMptwREkduVm
uRnkkUAIsBfAVq0TaXIrwvTJFYgIRQqyNory
vQgrKieWNquoYm0HAFLBlqAgndQwQeYrnIuq
mUtLZgucLarAF0udrInoqSpAltXECMleMlgn
jVCstbfmxBjLLjQBacHJaBMjBJyKdItoJuZQ
q0yZAHvkqqIXbWnLlyUpWZPYBphquULJtdpg
ELDLphSAvPnSgNRnxKmtsZFRAodaILvhcqtH
FssGwVYNNtGUfEppyqxMKvqpNfbpJUkVPwtK
DN0gAMVwRjuvhhwPgDspKGxRdHZGWuybZHCg
n1BqINuMvEuOpohVSiViItD0YkEEHSbfuDvVr
dwRocZEMcbrgxGINRoWAtQISvtZKAProfUcj
e0DqFtUdKQJ0YtJJTSXogFXkeNFijGgbAo0Z
urQvcYmGKZubToKHbWeNwfaiqsxjVNqgqoCr
QxYVMQqsc0mtScaj0vUrShLGfuLtxgQpxcgc
oVhZrYSmmH0pjLRZJbowWktavFvhGuhCABQl
FmodAqDqRjRccXqnrWIFkcRXbZ0DAqsPDp1T
KeyrCoTWKKE0QqNHSdrbZbrhoYNIQJc0onXp

yvvVvhRVZkckchjFMuWIZwGSxpFbhyeDIkWy
cWNHmQmVYSwNBVjXqprtWPGHjHpTeRMJkDLf
wyrbXywkbm0eoETDFgaEWRHpudXQnpeiQZcl
ZWpUlyQMJJHdXt1HiuMHxLQmiqUjdDgiAidR
AjEFhKUokTYwBBunFpuVs1rJscyaQCUFqbyD
JVioLLdjeMtxJpQORBuysceARWpMfXbNIkfr
YRhMTnvhdINm

Evidence Connection: close

Solution Rewrite the background program using proper return length checking. This will require a recompile of the background executable.

Risk=Low, Confidence=Medium (1)

<https://efbox.local:8081> (1)

Application Error Disclosure (1)

▼ GET <https://efbox.local:8081/folder/browse?folderID=>

- Alert tags**
- [WSTG-v42-ERRH-02](#)
 - [WSTG-v42-ERRH-01](#)
 - [OWASP_2021_A05](#)
 - POLICY_QA_STD =
 - POLICY_PENTEST =
 - [CWE-550](#)
 - [OWASP_2017_A06](#)
 - [OWASP_2025_A02](#)

Alert description This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a

documentation page.

Request

▼ Request line and header section (422 bytes)

```
GET https://efbox.local:8081/
folder/browse?folderID= HTTP/1.1
Authorization: Bearer
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJhdXRoMCIsInN1YiI6IjYzODQ4YTA3LWMzNzQtNGQ1Mi1iNWUxLWYxZjdkNTEzNTYxMSIsImV4cCI6MTc3OTE4OTA0MH0.a04X5C9H3cue35T8FFdX-
xrgmzL7NvLj8Q37dhd0NI8
User-Agent: PostmanRuntime/7.54.0
Accept: */*
Postman-Token: 3b261f99-a30b-45f2-
a7aa-1243e9e5f15e
host: efbox.local:8081
Connection: keep-alive
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (456 bytes)

```
HTTP/1.1 500
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-
Headers
X-Content-Type-Options: nosniff
X-XSS-Protection: 0
Cache-Control: no-cache, no-store,
max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Strict-Transport-Security: max-
age=31536000 ; includeSubDomains
X-Frame-Options: DENY
Content-Type: text/
plain; charset=UTF-8
```

Content-Length: 21
Date: Tue, 19 May 2026 10:39:00 GMT
Connection: close

▼ Response body (21 bytes)

Invalid UUID string:

Evidence HTTP/1.1 500

Solution Review the source code of this page.
Implement custom error pages. Consider implementing a mechanism to provide a unique error reference/identifier to the client (browser) while logging the details on the server side and not exposing them to the user.

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

SQL Injection

Source	raised by an active scanner (SQL Injection)
CWE ID	89
WASC ID	19
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Buffer Overflow

Source	raised by an active scanner (Buffer Overflow)
CWE ID	120
WASC ID	7
Reference	▪ https://owasp.org/www-community/attacks/Buffer_overflow_attack

Application Error Disclosure

Source	raised by a passive scanner (Application Error Disclosure)
CWE ID	550
WASC ID	13